
PLAN DE CONTINUIDAD OPERATIVA

Plan de Continuidad Operativa y Recuperación ante Incidentes

Caso de estudio: Montevideo Shopping Centers
Entorno de Retail Comercial

Alineada con ISO 22301 - ISO 31000 - ISO/IEC 27001 - NIST CSF 2.0

Preparado para	Montevideo Shopping Centers
Documento complementario	Assessment de Riesgos de Ciberseguridad y Resiliencia Operativa
Clasificación	Confidencial - Uso Interno
Elaborado Por	Francisco Noya
Versión	1.0
Fecha	13 de Julio de 2026

CONTROL DOCUMENTAL

Documento	Plan de Continuidad Operativa y Recuperación ante Incidentes
Versión	1.0
Fecha de emisión	13 de julio de 2026
Propietario del plan	Gerencia General / Área de Tecnología
Preparado por	Francisco Noya
Clasificación	Confidencial – Uso Interno
Frecuencia de revisión	Anual
Próxima revisión	Julio 2027
Estado	Vigente

Historial de cambios

Versión	Fecha	Descripción del cambio
1.0	13/07/2026	Emisión inicial del docume

1. Resumen Ejecutivo

1.1 Objetivo

El presente documento tiene como finalidad establecer un Plan de Continuidad Operativa y Recuperación ante Incidentes para un entorno de retail comercial, tomando como referencia las características operativas de Montevideo Shopping.

El plan se desarrolla como complemento del Assessment de Riesgos de Ciberseguridad y Resiliencia Operativa previamente elaborado, con el propósito de definir estrategias de preparación, respuesta y recuperación frente a eventos que puedan afectar la continuidad de las operaciones críticas del negocio.

La propuesta se encuentra alineada con los principios de ISO 22301, ISO 31000, ISO/IEC 27001 y NIST Cybersecurity Framework (CSF) 2.0, priorizando la disponibilidad de los servicios esenciales, la resiliencia organizacional y la capacidad de recuperación ante incidentes tecnológicos, operativos y de infraestructura.

1.2 Alcance

El plan contempla la continuidad y recuperación de los siguientes servicios críticos:

- Sistema de estacionamiento.
- Infraestructura eléctrica y generación de respaldo.
- Redes corporativas y conectividad a Internet.
- Sistemas administrativos.
- Videovigilancia (CCTV).
- Control de accesos.
- Atención al cliente.
- Operaciones administrativas esenciales.

La propuesta se desarrolla tomando como referencia las características operativas de un entorno de retail comercial de gran escala, utilizando información pública y buenas prácticas internacionales, sin acceso a información confidencial ni a la infraestructura interna de la organización.

1.3 Escenarios Prioritarios

Los escenarios priorizados fueron seleccionados en función de su probabilidad de ocurrencia y del impacto potencial sobre la continuidad de las operaciones críticas del negocio.

Ciberseguridad

- Ransomware.
- Indisponibilidad del sistema CCTV.

Infraestructura y operaciones

- Corte eléctrico prolongado.
- Caída de conectividad a Internet.
- Falla del sistema de parking.
- Incendio en áreas técnicas.

Dependencia de terceros

- Interrupción de servicios de proveedores críticos.

Estos escenarios constituyen la base para la definición de estrategias de respuesta, recuperación y priorización de recursos contempladas en el presente plan.

2. Objetivo del Plan

El objetivo del presente **Plan de Continuidad Operativa y Recuperación ante Incidentes** consiste en establecer lineamientos, procedimientos y estrategias que permitan mantener, restablecer y recuperar las operaciones críticas del centro comercial ante eventos disruptivos que afecten la disponibilidad de los servicios esenciales.

De manera específica, el plan busca:

- Reducir el impacto operativo de incidentes tecnológicos y operacionales.
- Definir tiempos objetivos de recuperación para los servicios críticos.
- Establecer procedimientos iniciales de respuesta y escalamiento.
- Asignar responsabilidades durante la gestión de incidentes.
- Preservar la continuidad de los procesos esenciales del negocio.
- Fortalecer la resiliencia organizacional frente a escenarios de interrupción.
- Facilitar la coordinación entre las áreas involucradas durante la recuperación operativa.

El cumplimiento de estos objetivos permitirá mejorar la capacidad de respuesta de la organización y contribuirá a minimizar el impacto financiero, operativo y reputacional asociado a incidentes que afecten la continuidad del negocio.

3. Alcance

El presente Plan de Continuidad Operativa contempla los procesos, servicios e infraestructura cuya disponibilidad resulta esencial para garantizar el funcionamiento de un centro comercial moderno.

Dentro del alcance del plan se consideran los siguientes componentes:

Componentes incluidos

- Sistema de estacionamiento.
- Infraestructura eléctrica y generación de respaldo.
- Redes corporativas y conectividad a Internet.
- Sistemas administrativos y financieros.
- Sistemas de videovigilancia (CCTV).
- Sistemas de control de accesos.
- Plataforma de atención al cliente.
- Procesos administrativos esenciales.
- Servicios prestados por proveedores críticos.

Quedan fuera del alcance:

Exclusiones del alcance

- Evaluaciones técnicas sobre infraestructura informática.
- Pruebas de penetración.
- Análisis de configuraciones de seguridad.
- Revisión de información confidencial.
- Auditorías oficiales de continuidad del negocio.

La propuesta se desarrolla tomando como referencia las características operativas de un entorno de retail comercial de gran escala, utilizando información pública y buenas prácticas internacionales de gestión de continuidad y resiliencia operativa.

4. Servicios Críticos

Los siguientes servicios fueron identificados como esenciales para la continuidad operativa del centro comercial. La clasificación de criticidad se realizó considerando el impacto potencial sobre la seguridad física, la operación comercial, la atención al cliente y la capacidad de mantener los procesos esenciales del negocio.

Servicio	Nivel de criticidad
Energía Eléctrica	Crítica
Generación eléctrica de respaldo	Crítica
Conectividad de Internet	Crítica
Red corporativa	Crítica
Videovigilancia (CCTV)	Crítica
Control de accesos	Crítica
Sistemas administrativos y financieros	Crítica
Sistema de parking	Alta
Atención al Cliente	Alta
Telefonía corporativa	Alta

La indisponibilidad de los servicios clasificados como críticos podría generar interrupciones inmediatas en la operación comercial, afectar la seguridad física de las instalaciones y comprometer la continuidad de los procesos esenciales del negocio.

Los servicios clasificados con criticidad alta podrían impactar significativamente la experiencia de clientes y locatarios, así como la eficiencia operativa, aunque existen mecanismos temporales de contingencia para su continuidad parcial.

5. Análisis de Impacto al Negocio (BIA)

5.1 Introducción

El **Análisis de Impacto al Negocio (Business Impact Analysis – BIA)** tiene como objetivo determinar las consecuencias operativas, financieras y reputacionales derivadas de la interrupción de los servicios críticos identificados en el presente plan.

El análisis permite establecer prioridades de recuperación y definir los tiempos objetivos de restablecimiento de cada servicio, considerando el impacto potencial sobre la operación comercial, la seguridad física, la atención a clientes y locatarios, y la continuidad de los procesos esenciales del negocio.

Los resultados del BIA constituyen la base para la definición de las estrategias de continuidad y recuperación desarrolladas en los capítulos siguientes.

5.2 Evaluación de Impacto

La evaluación de impacto se realizó considerando las consecuencias derivadas de la interrupción de cada servicio crítico sobre la operación comercial, los ingresos, la seguridad física y la percepción de clientes y locatarios.

Servicio	Impacto Operativo	Impacto Financiero	Impacto Reputacional
Energía Eléctrica	Crítico	Alto	Alto
Conectividad a internet	Crítico	Alto	Medio
Videovigilancia (CCTV)	Alto	Medio	Alto
Sistema de parking	Alto	Alto	Alto
Sistemas administrativos y financieros	Crítico	Alto	Medio
Control de accesos	Alto	Medio	Alto

Los resultados del análisis evidencian que la energía eléctrica, la conectividad a Internet y los sistemas administrativos y financieros presentan el mayor impacto operativo ante una interrupción, por lo que requieren estrategias de recuperación prioritaria.

Asimismo, el sistema de parking, la videovigilancia y el control de accesos muestran un impacto reputacional significativo debido a su relación directa con la experiencia de clientes, la seguridad física y la percepción de continuidad del servicio.

5.3 Metodología de Cuantificación de Impacto

Para evitar que la clasificación de impacto (Crítico/Alto/Medio) sea puramente cualitativa, se aplicó una metodología simplificada de cuantificación basada en tres variables:

- **Pérdida de ingresos por hora de interrupción (LDI):** ingresos promedio generados por el centro comercial en una hora de operación normal, ajustado por franja horaria (pico vs. valle) y día (hábil vs. fin de semana).
- **Costo de contingencia (CC):** costo operativo adicional de sostener el servicio mediante mecanismos manuales o alternativos (horas extra de personal, alquiler de equipos, etc.).
- **Factor de exposición reputacional (FER):** escala de 1 a 5 que estima el efecto sobre la percepción de clientes y locatarios, considerando visibilidad del incidente y facilidad de viralización (redes sociales, reclamos públicos).

Fórmula de impacto estimado por hora de interrupción:

Impacto Estimado (USD/hora) = LDI + CC + (FER × Factor de Ponderación Reputacional)

Supuestos ilustrativos utilizados para este caso de estudio

Variable	Supuesto ilustrativo	Fuente / Justificación
Ingresos promedio/hora (horario pico)	USD 15.000 – 25.000	Estimado en base a benchmarks públicos de centros comerciales de escala similar en la región
Ingresos promedio/hora (horario valle)	USD 3.000 – 6.000	Ídem
Costo de personal adicional (parking manual)	USD 150 – 300/hora	Estimado según 3-4 operarios adicionales a tarifa de mercado
Factor de ponderación reputacional	USD 500 – 2.000 por punto FER	Estimación conservadora, sin base empírica específica del caso

5.4 Tabla de Impacto Cuantificado (Ilustrativa)

Servicio	Impacto USD/hora (estimado, horario pico)	FER (1-5)	Criticidad resultante
----------	---	-----------	-----------------------

Energía eléctrica	18.000 – 28.000 (paraliza toda la operación)	5	Crítico
Conectividad a Internet	5.000 – 10.000 (afecta pagos electrónicos, e-commerce, correo)	3	Crítico
Sistemas administrativos y financieros	3.000 – 6.000	3	Crítico
Sistema de parking	2.000 – 4.000 + costo de contingencia manual	4	Alto
CCTV	Sin impacto directo en ingresos; impacto en seguridad y riesgo legal	4	Alto
Control de accesos	1.000 – 3.000 (riesgo de seguridad física)	4	Alto

Conclusión metodológica: esta cuantificación, aunque basada en supuestos, permite justificar de forma trazable por qué ciertos servicios reciben RTO más agresivos que otros — algo que la versión cualitativa (solo "Crítico/Alto/Medio") no permite sustentar ante una auditoría o comité directivo. En una implementación real, estos valores deben reemplazarse por datos históricos de ventas, costos operativos reales y encuestas de percepción de marca.

6. RTO y RPO

6.1 Objetivos de Recuperación

Los tiempos objetivos de recuperación fueron definidos considerando el nivel de criticidad de cada servicio y el impacto identificado en el Análisis de Impacto al Negocio (BIA).

Servicio	RTO	RPO
Energía Eléctrica	1 Hora	No Aplica
Conectividad a internet	2 Horas	30 Minutos
Videovigilancia (CCTV)	2 Horas	15 Minutos
Sistema de parking	2 Horas	15 Minutos
Sistemas administrativos y financieros	4 Horas	1 Hora
Control de accesos	1 Hora	15 Minutos
Atención al cliente	4 Horas	1 Hora

6.2 Definiciones

RTO Recovery Time Objective

Tiempo máximo aceptable para restablecer un servicio tras una interrupción.

RPO Recovery Point Objective

Cantidad máxima de información que la organización puede perder antes de la recuperación del servicio.

Conclusión ejecutiva

Los objetivos definidos priorizan la recuperación temprana de los servicios relacionados con seguridad física, energía y control de accesos, mientras que los sistemas administrativos y de atención al cliente disponen de ventanas de recuperación mayores debido a la existencia de procedimientos operativos temporales de contingencia.

6.3 Metodología de Definición de RTO/RPO

Los tiempos objetivo no se definieron de forma arbitraria, sino aplicando el siguiente criterio de decisión:

1. **Punto de partida:** el impacto cuantificado por hora (capítulo 5.3-5.4) determina la "urgencia económica" de la recuperación.
2. **Ajuste por capacidad técnica real:** el RTO no puede ser menor al tiempo mínimo técnicamente alcanzable (ej.: un generador diésel tarda típicamente 10-15 segundos en arrancar más el tiempo de transferencia de carga; por eso energía tiene RTO de 1 hora y no de minutos — ese margen contempla fallas del sistema de arranque automático y verificación manual).
3. **Punto de equilibrio costo-beneficio:** se compara el costo de una recuperación más rápida (redundancia adicional, contratos de soporte 24/7, sitios alternos) contra el costo de la interrupción evitada. Un RTO agresivo que cueste más que el impacto que previene no se justifica.

Ejemplo de razonamiento aplicado (Energía eléctrica → RTO 1 hora):

- Impacto de interrupción: ~USD 20.000/hora en horario pico.
- Costo de una solución que baje el RTO a 15 minutos (UPS de mayor capacidad + generadores redundantes N+1): inversión estimada significativamente mayor a la reducción de impacto marginal, dado que ya existe generación de respaldo.
- Conclusión: se mantiene RTO de 1 hora, pero se recomienda evaluar redundancia N+1 solo si el historial de incidentes muestra fallas recurrentes del sistema de arranque automático.

Ejemplo de razonamiento aplicado (Sistemas administrativos → RTO 4 horas):

- Impacto menor y existen procedimientos manuales de contingencia (facturación manual, registro en papel).
- El costo de un RTO más agresivo (ej. 1 hora, vía servidores redundantes activos-activos) no se justifica frente al impacto evitado.
- Conclusión: RTO 4 horas es razonable, apoyado en procedimientos manuales temporales.

Esta trazabilidad — impacto cuantificado → capacidad técnica → costo-beneficio — es lo que un revisor técnico o auditor de ISO 22301 espera encontrar detrás de cada valor de RTO/RPO, en lugar de una tabla de números sin respaldo.

6.4 Maximum Tolerable Period of Disruption (MTPD)

Además de los objetivos RTO y RPO, se definió el período máximo tolerable de interrupción (MTPD) para cada servicio crítico, entendido como el tiempo máximo durante el cual la organización puede operar antes de que el impacto resulte inaceptable.

Servicio	MTPD
Energía eléctrica	2 horas
Control de accesos	2 horas
CCTV	4 horas
Conectividad a Internet	6 horas
Sistemas administrativos	8 horas
Sistema de parking	6 horas
Atención al cliente	8 horas

Los valores de MTPD permiten verificar que los RTO definidos se encuentran dentro de un margen aceptable de recuperación y constituyen un criterio adicional para la priorización de recursos durante una contingencia.

7. Escenarios de Interrupción

7.1 Introducción

El presente capítulo identifica los principales escenarios de interrupción que podrían afectar la continuidad operativa del centro comercial.

Los escenarios fueron seleccionados considerando los riesgos prioritarios identificados durante el Assessment de Riesgos de Ciberseguridad y Resiliencia Operativa y su potencial impacto sobre los servicios críticos del negocio.

Cada escenario contempla una descripción general del evento, los servicios potencialmente afectados y el nivel de criticidad asociado, con el objetivo de facilitar la definición de los procedimientos de respuesta, continuidad y recuperación establecidos en los capítulos siguientes.

7.2 Escenario 1 – Ataque de Ransomware

Crítico

Descripción

Compromiso de sistemas corporativos mediante software malicioso diseñado para cifrar información y provocar la indisponibilidad de servicios tecnológicos.

Servicios potencialmente afectados

- Sistemas administrativos y financieros.
- Correo electrónico corporativo.
- Plataforma de atención al cliente.
- Sistemas de gestión documental.
- Recursos compartidos de red.

Impacto potencial

- Interrupción de procesos administrativos.
- Indisponibilidad de información crítica.
- Retrasos operativos significativos.
- Afectación de la atención a clientes y locatarios.
- Impacto reputacional y financiero.

Objetivo de recuperación asociado

Priorizar la contención del incidente, restaurar los servicios críticos afectados y recuperar la información respaldada dentro de los tiempos RTO y RPO definidos en el capítulo 6.

7.3 Escenario 2 – Corte Eléctrico Prolongado

Crítico

Descripción

Interrupción extendida del suministro eléctrico que excede la capacidad de respuesta inmediata de los sistemas de respaldo.

Servicios potencialmente afectados

- Redes corporativas.
- Videovigilancia (CCTV).
- Control de accesos.
- Sistema de parking.
- Sistemas administrativos y financieros.
- Escaleras mecánicas y ascensores.

Impacto potencial

- Suspensión parcial de operaciones.
- Afectación de la seguridad física.
- Limitaciones en el acceso de clientes y proveedores.
- Interrupción de procesos administrativos.
- Activación de planes de contingencia.

Objetivo de recuperación asociado

Restablecer el suministro eléctrico mediante los sistemas de generación de respaldo disponibles y recuperar progresivamente los servicios críticos priorizando la seguridad física, el control de accesos y la conectividad interna.

7.4 Escenario 3 – Caída de Conectividad a Internet

Alto

Descripción

Indisponibilidad de los servicios de telecomunicaciones que soportan la conectividad externa del centro comercial.

Servicios potencialmente afectados

- Correo electrónico corporativo.
- Servicios en la nube.
- Plataformas de gestión remota.
- Sistemas que dependen de la conectividad externa.
- Comunicación con proveedores.
- Acceso a aplicaciones corporativas externas.

Impacto potencial

- Limitaciones operativas.
- Pérdida de comunicaciones externas.
- Retrasos administrativos.
- Afectación de servicios digitales.
- Demoras en la coordinación con proveedores y terceros.

Objetivo de recuperación asociado

Restablecer la conectividad externa mediante enlaces redundantes o mecanismos alternativos de comunicación y priorizar los servicios esenciales dependientes de Internet.

7.5 Escenario 4 – Falla del Sistema de Parking

Alto

Descripción

Indisponibilidad del sistema de gestión del estacionamiento, incluyendo barreras automáticas, emisión de tickets y control de ingreso y egreso de vehículos.

Servicios potencialmente afectados

- Ingreso de vehículos.
- Egreso de vehículos.
- Cobro del estacionamiento.
- Atención al usuario del parking.
- Control de ocupación de plazas.
- Generación de reportes operativos del estacionamiento.

Impacto potencial

- Congestión vehicular.
- Demoras operativas.
- Reclamos de clientes.
- Impacto reputacional.
- Incremento de la carga de trabajo del personal operativo.

Objetivo de recuperación asociado

Implementar procedimientos manuales de ingreso y egreso vehicular mientras se restablece el sistema automatizado de estacionamiento, minimizando el impacto sobre la circulación y la atención a los usuarios.

7.6 Escenario 5 – Indisponibilidad de CCTV

Alto

Descripción

Pérdida total o parcial de los sistemas de videovigilancia utilizados para el monitoreo de seguridad física.

Servicios potencialmente afectados

- Centro de monitoreo.
- Supervisión de áreas comunes.
- Monitoreo de estacionamientos.
- Apoyo a investigaciones de incidentes.
- Registro de eventos de seguridad.
- Coordinación operativa del personal de vigilancia.

Impacto potencial

- Reducción de la capacidad de vigilancia.
- Incremento del riesgo de incidentes físicos.
- Limitaciones en la respuesta del personal de seguridad.
- Dificultades para la investigación de eventos ocurridos durante la interrupción.
- Mayor dependencia de controles de seguridad presenciales.

Objetivo de recuperación asociado

Restablecer las cámaras y el centro de monitoreo priorizando las áreas de mayor riesgo y reforzar temporalmente la vigilancia presencial hasta la recuperación completa del servicio.

7.7 Escenario 6 – Incendio en Área Técnica

Crítico

Descripción

Evento de incendio que afecte salas eléctricas, cuartos de comunicaciones o infraestructura técnica crítica.

Servicios potencialmente afectados

- Distribución eléctrica.
- Red corporativa.
- Sistemas administrativos y financieros.
- Videovigilancia (CCTV).
- Control de accesos.
- Conectividad interna.
- Sistemas de comunicación operativa.

Impacto potencial

- Interrupción severa de operaciones.
- Daños a infraestructura crítica.
- Evacuación de áreas afectadas.
- Activación de planes de emergencia.
- Pérdida temporal de servicios tecnológicos esenciales.
- Incremento del tiempo de recuperación operativa.

Objetivo de recuperación asociado

Contener el incidente, garantizar la seguridad de las personas y recuperar progresivamente la infraestructura técnica afectada mediante la activación de los procedimientos de emergencia, continuidad y recuperación establecidos.

7.8 Escenario 7 – Interrupción de Proveedor Crítico

Alto

Descripción

Falla significativa de un proveedor esencial para la operación del centro comercial, incluyendo servicios de telecomunicaciones, energía, seguridad o soporte tecnológico.

Servicios potencialmente afectados

- Conectividad a Internet.
- Soporte técnico especializado.
- Seguridad física.
- Mantenimiento de infraestructura crítica.

- Servicios operativos esenciales.
- Asistencia ante incidentes tecnológicos.

Impacto potencial

- Degradación de servicios críticos.
- Retrasos en la recuperación operativa.
- Dependencia de soluciones alternativas.
- Afectación de la continuidad operativa.
- Incremento de costos asociados a contingencias.
- Mayor exposición a interrupciones prolongadas.

Objetivo de recuperación asociado

Activar proveedores alternativos, acuerdos de soporte priorizados y mecanismos de contingencia que permitan mantener o restablecer los servicios esenciales con el menor impacto posible sobre la operación del centro comercial.

7.9 Matriz Resumen de Escenarios

La siguiente matriz consolida los escenarios de interrupción analizados y su nivel de criticidad asociado, permitiendo visualizar las prioridades de continuidad y recuperación definidas en el presente plan.

Escenario	Nivel de Criticidad
Ataque de ransomware	Crítico
Corte eléctrico programado	Crítico
Caída de conectividad a internet	Alto
Falla del sistema de parking	Alto
Indisponibilidad de CCTV	Alto
Incendio en área técnica	Crítico
Interrupción de proveedor crítico	Alto

La matriz evidencia que los escenarios de ransomware, corte eléctrico prolongado e incendio en área técnica representan el mayor nivel de criticidad para la continuidad operativa del centro comercial y requieren una recuperación prioritaria.

Los escenarios clasificados con criticidad alta demandan mecanismos de contingencia específicos para minimizar la degradación de los servicios y mantener la operación dentro de los tiempos objetivos definidos en el capítulo 6.

7.10 Conclusiones

El análisis de escenarios evidencia que los eventos con mayor impacto potencial sobre la continuidad del negocio corresponden a ataques de ransomware, cortes eléctricos prolongados e incendios en áreas técnicas, debido a su capacidad de comprometer simultáneamente múltiples servicios críticos e infraestructura esencial.

Los escenarios clasificados con criticidad alta también requieren procedimientos específicos de respuesta y contingencia, ya que pueden generar interrupciones significativas en la operación diaria, afectar la experiencia de clientes y locatarios y limitar temporalmente la capacidad de recuperación de la organización.

La priorización realizada en este capítulo se encuentra alineada con los resultados del Análisis de Impacto al Negocio (BIA) y con los objetivos de recuperación (RTO y RPO) definidos previamente, constituyendo la base para la planificación de las estrategias de continuidad y recuperación.

En el capítulo siguiente se desarrollarán los procedimientos de respuesta inicial y recuperación asociados a cada uno de los escenarios priorizados, con el objetivo de reducir el tiempo de interrupción y minimizar el impacto operativo, financiero y reputacional sobre el negocio.

7.A Estrategias de Continuidad y Redundancia

7.A.1 Introducción

Mientras que los capítulos anteriores definen *qué* debe recuperarse y *en cuánto tiempo*, el presente capítulo define *mediante qué mecanismos* la organización logra sostener la operación durante la interrupción y cumplir los RTO/RPO establecidos. Sin esta capa de estrategias, los tiempos objetivo definidos en el capítulo 6 carecen de un mecanismo concreto que los haga alcanzables.

7.A.2 Estrategia de Redundancia Eléctrica

- **Nivel 1 – UPS:** cobertura de continuidad inmediata (0-30 segundos) para sistemas críticos (CCTV, control de accesos, red core) durante la transferencia a generación de respaldo.
- **Nivel 2 – Generación de respaldo (diésel/gas):** dimensionada para sostener el 100% de las cargas críticas y al menos el 60-70% de las cargas de confort (climatización parcial, iluminación esencial) durante un mínimo de 8-12 horas continuas sin reabastecimiento.
- **Nivel 3 – Contrato de reabastecimiento de combustible de emergencia:** acuerdo con proveedor que garantice reabastecimiento en menos de 4 horas ante interrupciones prolongadas (>12 horas).
- **Recomendación de redundancia N+1** para sistemas de generación en caso de que el análisis de incidentes históricos muestre fallas recurrentes de arranque automático.

7.A.3 Estrategia de Redundancia de Conectividad

- **Doble proveedor de Internet (dual-WAN)** con enlaces de distinta traza física (evitar que ambos proveedores compartan el mismo ducto o poste), conmutación automática (failover) en menos de 60 segundos.
- **Enlace de respaldo vía tecnología alternativa** (ej. 4G/5G o satelital de baja latencia) para operaciones mínimas esenciales (pagos electrónicos, comunicación con Gerencia) en caso de falla simultánea de ambos proveedores primarios.
- **Segmentación de red** que permita priorizar tráfico crítico (control de accesos, CCTV, sistemas de pago) sobre tráfico no esencial durante degradación de ancho de banda.

7.A.4 Estrategia de Respaldo y Recuperación de Datos (Backup)

- **Regla 3-2-1:** al menos 3 copias de la información, en 2 tipos de medios distintos, con 1 copia fuera del sitio (offsite) o en la nube.
- **Copia inmutable / air-gapped** para al menos un set de respaldos, específicamente como control anti-ransomware (los respaldos conectados permanentemente a la red son cifrables por el mismo ataque que compromete los sistemas de producción).
- **Pruebas de restauración periódicas** (no solo verificación de que el backup "corrió", sino restauración real y verificación de integridad) — vinculado a la recomendación ya existente en el capítulo 14 del plan original, pero ahora con mecanismo concreto.

7.A.5 Estrategia Anti-Ransomware (Prevención, no solo respuesta)

El plan original cubre bien la *respuesta* a ransomware (capítulo 8.3) pero no la *prevención estructural*. Se recomienda incorporar:

- Segmentación de red (red de sistemas administrativos separada de red de CCTV/control de accesos, para que el compromiso de una no implique el compromiso de la otra).
- Principio de privilegio mínimo y autenticación multifactor (MFA) en accesos administrativos y remotos.
- Filtrado de correo y capacitación anti-phishing periódica (el vector de entrada más común de ransomware).
- Monitoreo de comportamiento anómalo (EDR/XDR) sobre endpoints críticos.

7.A.6 Estrategia de Sitio Alterno / Operación Degradada

Para los sistemas administrativos y financieros, se recomienda definir un **modo de operación degradada documentado** (no solo "activar el manual"), que incluya:

- Formularios físicos pre-impresos para registro de operaciones críticas.
- Ubicación física designada como centro de comando alternativo si el área técnica principal queda inhabilitada (ej. por incendio).
- Lista de personal clave con roles de respaldo (backup de responsables) para cada función crítica, evitando puntos únicos de falla humana.

7.A.7 Estrategia de Gestión de Proveedores Críticos

- Cláusulas contractuales de SLA con tiempos de respuesta explícitos, alineados a los RTO internos (ej.: si el RTO de conectividad es 2 horas, el SLA del proveedor de Internet no puede prometer 4 horas).
- Identificación de proveedor alternativo pre-calificado para cada servicio crítico tercerizado, evitando negociar en medio de la crisis.

- Cláusulas de penalidad y de continuidad del propio proveedor (que el proveedor tenga, a su vez, su propio plan de continuidad).

7.A.8 Matriz Resumen de Estrategias vs. RTO Objetivo

Servicio	RTO Objetivo	Estrategia principal que lo sostiene
Energía eléctrica	1 hora	UPS + generación de respaldo + contrato de combustible de emergencia
Conectividad a Internet	2 horas	Dual-WAN con failover automático + enlace 4G/5G de respaldo
CCTV	2 horas	Alimentación redundante (UPS dedicada) + vigilancia presencial de contingencia
Sistemas administrativos	4 horas	Backup 3-2-1 con copia inmutable + procedimiento manual documentado
Sistema de parking	2 horas	Procedimiento manual + contrato de soporte prioritario con proveedor

Esta matriz es la pieza que conecta el "qué tiempo" (capítulo 6) con el "cómo se logra" (este capítulo) — sin ella, los RTO son una aspiración, no un compromiso operativo sustentado.

8. Procedimientos de Respuesta Inicial y Recuperación

8.1 Introducción

El presente capítulo establece los procedimientos de respuesta inicial y recuperación ante los escenarios de interrupción identificados en el análisis de continuidad operativa.

Las acciones definidas tienen como objetivo contener los incidentes, reducir el impacto sobre los servicios críticos, coordinar la respuesta entre las áreas involucradas y facilitar la recuperación de las operaciones dentro de los tiempos objetivos establecidos.

8.2 Activación del Plan

El Plan de Continuidad Operativa deberá activarse cuando un incidente afecte o tenga el potencial de afectar la disponibilidad de uno o más servicios críticos identificados en el presente documento.

La activación podrá ser realizada por las áreas de Tecnología, Seguridad, Operaciones o Gerencia General, dependiendo de la naturaleza, alcance e impacto del evento.

Criterios de activación

- Interrupción de servicios críticos superior a 30 minutos.
- Compromiso de sistemas administrativos esenciales.
- Falla de infraestructura eléctrica crítica.
- Incidente de ciberseguridad con impacto operativo.
- Evento físico que requiera evacuación o suspensión parcial de operaciones.

8.3 Procedimiento – Ransomware

Nivel de criticidad: Crítico

Acciones inmediatas

- Aislar los equipos comprometidos de la red.
- Notificar inmediatamente al área de Tecnología.
- Suspender accesos remotos no esenciales.
- Preservar evidencias para análisis posterior.
- Verificar el estado de los respaldos disponibles.
- Evaluar el alcance del incidente.

Objetivo de recuperación

Parámetro	Objetivo
-----------	----------

RTO	4 Horas
RPO	1 Hora

Áreas involucradas

- Tecnología.
- Administración.
- Gerencia General.
- Atención al Cliente.

8.4 Procedimiento – Corte Eléctrico Prolongado

Nivel de criticidad: Crítico

Acciones inmediatas

- Confirmar la activación de generadores eléctricos.
- Verificar el funcionamiento de UPS críticas.
- Priorizar energía para sistemas esenciales.
- Coordinar con mantenimiento y proveedor eléctrico.
- Evaluar la necesidad de aplicar restricciones operativas.

Servicios prioritarios

- Videovigilancia (CCTV).
- Control de accesos.
- Red corporativa.
- Sistemas administrativos.
- Sistema de parking.

8.5 Procedimiento – Caída de Conectividad a Internet

Nivel de criticidad: Alto

Acciones inmediatas

- Verificar si la falla corresponde a infraestructura interna o al proveedor.
- Activar enlaces alternativos si se encuentran disponibles.
- Priorizar servicios críticos dependientes de conectividad.
- Informar a las áreas afectadas.
- Registrar hora de inicio del incidente.

Objetivo de recuperación

Parámetro	Objetivo
RTO	2 horas
RPO	30 minutos

8.6 Procedimiento – Falla del Sistema de Parking

Nivel de criticidad: Alto

Acciones inmediatas

- Habilitar procedimiento manual de ingreso y egreso vehicular.
- Coordinar personal adicional de apoyo.
- Informar a Seguridad y Atención al Cliente.
- Registrar tickets manuales cuando corresponda.
- Escalar el incidente al área de Tecnología.
- Coordinar asistencia del proveedor del sistema.

Objetivo de recuperación

Parámetro	Objetivo
RTO	2 horas
RPO	15 minutos

8.7 Procedimiento – Indisponibilidad de CCTV

Nivel de criticidad: Alto

Acciones inmediatas

- Confirmar la pérdida total o parcial del sistema de videovigilancia.
- Notificar al área de Seguridad y Tecnología.
- Identificar cámaras o zonas afectadas.
- Reforzar temporalmente la vigilancia presencial.
- Priorizar la recuperación de áreas críticas.

Objetivo de recuperación

Parámetro	Objetivo
RTO	2 horas
RPO	15 minutos

Áreas involucradas

- Seguridad.
- Tecnología.
- Operaciones.

- Gerencia.

8.8 Procedimiento – Incendio en Área Técnica

Nivel de criticidad: Crítico

Acciones inmediatas

- Activar protocolo de emergencia.
- Coordinar evacuación del área afectada.
- Notificar a Seguridad y Mantenimiento.
- Aislar la infraestructura comprometida.
- Evaluar impacto sobre servicios críticos.
- Iniciar plan de recuperación de infraestructura.

Prioridades de actuación

1. Seguridad de las personas.
2. Contención del incidente.
3. Protección de infraestructura crítica.
4. Restablecimiento de servicios esenciales.

8.9 Procedimiento – Interrupción de Proveedor Crítico

Nivel de criticidad: Alto

Acciones inmediatas

- Confirmar la indisponibilidad del servicio proporcionado por terceros.
- Contactar al proveedor correspondiente.
- Evaluar impacto sobre servicios críticos.
- Activar mecanismos alternativos cuando estén disponibles.
- Coordinar acciones de recuperación con terceros.

Servicios afectados potencialmente

- Conectividad.
- Soporte técnico.
- Seguridad física.
- Mantenimiento especializado.

- Servicios operativos esenciales.

Objetivo de recuperación

Mantener o restablecer los servicios esenciales mediante proveedores alternativos, mecanismos de contingencia y acuerdos de soporte priorizados.

8.10 Escalamiento y Coordinación

Niveles de escalamiento

Nivel	Responsable
Operativo	Área afectada
Táctico	Tecnología / Seguridad / Operaciones
Estratégico	Gerencia General

Los incidentes clasificados como **Críticos** deberán ser escalados inmediatamente al nivel estratégico para coordinar la toma de decisiones relacionadas con continuidad operativa, comunicación institucional y recuperación del negocio.

La coordinación entre las áreas involucradas permitirá reducir los tiempos de respuesta y asegurar una gestión ordenada del incidente.

9. Matriz de Responsables

9.1 Introducción

La presente matriz tiene como objetivo definir las responsabilidades principales durante la activación del Plan de Continuidad Operativa, permitiendo una coordinación clara entre las distintas áreas involucradas en la gestión de incidentes.

La siguiente matriz identifica las áreas responsables de ejecutar las acciones de respuesta y las áreas de apoyo que participan en la coordinación y recuperación de los servicios afectados durante un incidente.

Para este caso de estudio se consideran las siguientes áreas:

- Gerencia General
- Tecnología
- Seguridad Física
- Operaciones
- Mantenimiento
- Atención al Cliente

9.2 Matriz RACI de Responsabilidades

R = Responsable | A = Aprobador | C = Consultado | I = Informado

Actividad	Gerencia	Tecnología	Seguridad	Operaciones	Mantenimiento	At. Cliente
Activación del plan	A	C	I	R	I	I
Gestión de ransomware	A	R	C	I	I	I
Recuperación de sistemas	I	R	I	C	I	I
Corte eléctrico prolongado	I	C	I	C	R	I
Incendio en área técnica	A	C	R	C	C	I

Falla del sistema de parking	I	C	I	R	I	C
Comunicación institucional	A	I	I	C	I	R
Coordinación con proveedores	A	R	I	R	C	I
Cierre del incidente	A	R	C	C	C	I

9.3 Niveles de Escalamiento

Nivel	Criterio	Ejemplo
Operativo	Incidentes de bajo impacto controlados por el área afectada.	Falla menor de un equipo.
Táctico	Incidentes con impacto sobre uno o más servicios críticos.	Caída del sistema de parking.
Estratégico	Incidentes críticos que afecten la continuidad del negocio o la reputación institucional.	Ransomware o incendio con interrupción de operaciones.

9.4 Conclusiones

La definición clara de responsabilidades permite reducir los tiempos de respuesta, evitar la duplicidad de tareas y mejorar la coordinación entre las áreas involucradas durante la gestión de incidentes críticos.

Asimismo, la incorporación de niveles de escalamiento facilita la toma de decisiones y asegura que los incidentes sean gestionados por el nivel organizacional correspondiente según su impacto operativo, financiero y reputacional.

La presente matriz constituye un elemento fundamental para la activación efectiva del Plan de Continuidad Operativa y para el fortalecimiento de la resiliencia organizacional ante eventos disruptivos.

10. Plan de Comunicación

10.1 Objetivo

El presente Plan de Comunicación tiene como finalidad asegurar que la información relacionada con incidentes críticos sea transmitida de manera oportuna, clara y coordinada a las partes interesadas internas y externas.

Una comunicación adecuada contribuye a reducir la incertidumbre, facilitar la toma de decisiones, mantener la coordinación operativa y minimizar el impacto reputacional derivado de eventos disruptivos.

10.2 Principios de Comunicación

- Rapidez: comunicar el incidente tan pronto como haya sido validado por el área responsable.
- Precisión: evitar la difusión de información no confirmada o especulativa.
- Coordinación: centralizar la comunicación institucional para asegurar mensajes coherentes.
- Confidencialidad: proteger la información sensible, técnica o de carácter interno.
- Consistencia: mantener mensajes alineados entre todas las áreas involucradas.

10.3 Comunicación Interna

Evento	Canal Principal	Canal Alternativo
Ransomware	Correo corporativo	Mensajería corporativa

Corte eléctrico	Teléfono	Radio / Mensajería
Incendio	Alarma de emergencia	Teléfono / Radio
Caída de Internet	Mensajería alternativa	Teléfono
Falla del sistema de parking	Operaciones	Atención al Cliente

10.4 Comunicación Externa

Cuando el incidente tenga impacto sobre clientes, locatarios o proveedores, la comunicación externa deberá ser coordinada por la Gerencia General.

Las principales partes interesadas consideradas en este caso de estudio son:

- Locatarios.
- Clientes.
- Proveedores críticos.
- Empresas de mantenimiento.
- Autoridades competentes, cuando corresponda.

10.5 Mensaje Inicial de Contingencia

“Se informa que actualmente se está gestionando una contingencia operativa que afecta determinados servicios del centro comercial. Los equipos responsables se encuentran trabajando para restablecer la operación en el menor tiempo posible. Se proporcionarán actualizaciones a medida que se disponga de nueva información confirmada.”

10.6 Frecuencia de Actualización

Nivel del incidente	Frecuencia de actualización
Crítico	Cada 30 minutos

Alto	Cada 60 minutos
Medio	Cada 2 horas
Bajo	Según necesidad

10.7 Registro de Comunicaciones

Durante la gestión de incidentes críticos deberá mantenerse un registro formal de las comunicaciones realizadas, incluyendo:

- Fecha y hora de cada comunicación.
- Responsable del mensaje.
- Destinatarios.
- Canal utilizado.
- Contenido resumido de la comunicación.
- Confirmación de recepción, cuando corresponda.

10.8 Roles de Comunicación

Actividad	Área Responsable
Aprobación del mensaje institucional	Gerencia General
Comunicación técnica interna	Tecnología

Comunicación operativa	Operaciones
Atención a consultas de clientes	Atención al Cliente
Coordinación con proveedores	Tecnología / Operaciones

10.9 Conclusiones

Un proceso de comunicación estructurado constituye un componente esencial del Plan de Continuidad Operativa, ya que permite mantener la coordinación organizacional, reducir el impacto reputacional y asegurar que las decisiones de respuesta y recuperación se ejecuten de manera eficiente durante situaciones de crisis.

La definición de principios, canales, frecuencias de actualización y responsabilidades contribuye a fortalecer la capacidad de respuesta de la organización ante eventos que puedan afectar la continuidad de sus operaciones.

10.A Dependencias de Servicios Críticos

La recuperación efectiva de los servicios críticos requiere considerar las dependencias existentes entre los distintos componentes tecnológicos y operativos.

Servicio	Depende de
CCTV	Energía eléctrica, red corporativa
Control de accesos	Energía eléctrica, red corporativa
Sistema de parking	Energía eléctrica, red corporativa, conectividad
Sistemas administrativos	Energía eléctrica, red corporativa, almacenamiento

Atención al cliente	Sistemas administrativos, conectividad
---------------------	--

Conclusión

Estas dependencias justifican el orden de recuperación definido en el capítulo 11, priorizando inicialmente la energía eléctrica, el control de accesos y la infraestructura de red antes de restablecer los servicios administrativos y de atención al cliente.

11. Recuperación de Servicios

11.1 Objetivo

El presente capítulo establece el orden de recuperación de los servicios críticos y las acciones generales necesarias para restablecer la operación normal del centro comercial una vez controlado el incidente.

La recuperación deberá ejecutarse de manera priorizada, considerando el impacto operativo, la seguridad física de las instalaciones, la disponibilidad de los sistemas esenciales y la continuidad del negocio.

11.2 Prioridad de Recuperación

Prioridad	Servicio Crítico
1	Energía eléctrica y sistemas de respaldo
2	Control de accesos y CCTV
3	Red corporativa e Internet
4	Sistemas administrativos

5	Sistema de parking
6	Servicios de atención al cliente

La secuencia de recuperación podrá ajustarse en función de la naturaleza del incidente y de las condiciones operativas existentes al momento de la contingencia.

11.3 Procedimiento General de Recuperación

1. Verificar que el incidente haya sido contenido y que no existan riesgos adicionales para las personas o la infraestructura.
2. Evaluar el estado de los sistemas, equipos y servicios afectados.
3. Restablecer prioritariamente los servicios clasificados con mayor criticidad.
4. Validar la integridad de los sistemas recuperados y de la información procesada.
5. Confirmar el correcto funcionamiento operativo mediante pruebas de verificación.
6. Documentar las acciones realizadas durante el proceso de recuperación.
7. Autorizar formalmente el retorno a la operación normal.

11.4 Validaciones Posteriores

Antes de declarar la recuperación completa deberán verificarse, como mínimo, los siguientes aspectos:

Disponibilidad de los sistemas críticos.



Conectividad de red y acceso a Internet.



Funcionamiento del sistema de CCTV.



Operación del sistema de control de accesos.

✓

Operación del sistema de parking.

✓

Acceso a aplicaciones administrativas.

✓

Correcta comunicación entre las áreas involucradas.

✓

11.5 Criterios de Cierre de Recuperación

La recuperación se considerará finalizada cuando se cumplan simultáneamente las siguientes condiciones:

- Todos los servicios priorizados hayan sido restablecidos.
- Las áreas responsables confirmen el funcionamiento adecuado de los sistemas bajo su gestión.
- No existan restricciones operativas significativas que afecten la continuidad de las actividades.
- Se hayan registrado las acciones de recuperación y las validaciones efectuadas.
- La Gerencia General autorice el cierre formal del incidente.

11.6 Registro de Recuperación

Durante el proceso de recuperación deberá mantenerse un registro que incluya:

Elemento	Descripción
Fecha y hora de inicio	Momento en que comenzó la recuperación.
Servicio afectado	Nombre del servicio o sistema recuperado.
Responsable	Área o persona a cargo de la recuperación.

Acciones ejecutadas	Actividades realizadas para el restablecimiento.
Resultado de validación	Confirmación de funcionamiento correcto.
Fecha y hora de cierre	Momento de finalización de la recuperación.

11.7 Conclusiones

La recuperación priorizada de los servicios críticos permite reducir el tiempo de interrupción operativa y asegurar que las funciones esenciales del centro comercial sean restablecidas de forma ordenada y controlada.

La aplicación de validaciones posteriores y criterios formales de cierre contribuye a garantizar que el retorno a la operación normal se realice con niveles adecuados de seguridad, disponibilidad y confiabilidad.

12. Pruebas y Simulacros

12.1 Objetivo

Las pruebas y simulacros tienen como finalidad verificar la efectividad del Plan de Continuidad Operativa, validar los procedimientos establecidos y fortalecer la capacidad de respuesta de la organización ante eventos que puedan afectar la continuidad de las operaciones.

Asimismo, permiten identificar oportunidades de mejora, evaluar la coordinación entre las áreas involucradas y confirmar que los tiempos de recuperación definidos sean razonablemente alcanzables.

12.2 Tipos de Prueba

Tipo de prueba	Objetivo principal
Prueba documental	Revisar procedimientos, responsabilidades y criterios de escalamiento.

Simulacro de ransomware	Validar la respuesta del área de Tecnología ante un incidente de ciberseguridad.
Simulacro de corte eléctrico	Verificar la operación de los sistemas de respaldo y la continuidad de los servicios críticos.
Simulacro de incendio	Evaluar los procedimientos de evacuación y la coordinación de emergencia.
Prueba de recuperación	Confirmar los tiempos de restablecimiento de los servicios críticos.

12.3 Frecuencia Recomendada

Actividad	Frecuencia
Revisión documental del plan	Semestral
Simulacro de ransomware	Anual
Simulacro de corte eléctrico	Anual

Simulacro de incendio	Anual
Prueba de recuperación de sistemas	Semestral

La frecuencia podrá ajustarse en función de cambios significativos en la infraestructura, incorporación de nuevos sistemas o resultados de evaluaciones de riesgo.

12.4 Evaluación de Resultados

Cada prueba o simulacro deberá documentar, como mínimo, los siguientes elementos:

Fecha y hora de ejecución.

✓

Escenario evaluado.

✓

Áreas participantes.

✓

Tiempos de respuesta observados.

✓

Desviaciones identificadas respecto a los procedimientos definidos.

✓

Acciones de mejora recomendadas.

✓

Responsable del seguimiento de las mejoras.

✓

12.5 Criterios de Éxito

Un simulacro se considerará satisfactorio cuando:

- Las áreas involucradas respondan conforme a las responsabilidades definidas.
- Los canales de comunicación funcionen adecuadamente.
- Los tiempos de respuesta se encuentren dentro de los objetivos establecidos.
- Las desviaciones detectadas no comprometan la continuidad de las operaciones.

- Se documenten las lecciones aprendidas y las acciones correctivas correspondientes.

12.6 Mejora Continua

Los resultados de las pruebas y simulacros deberán utilizarse para:

- Actualizar procedimientos y documentación.
- Ajustar responsabilidades y mecanismos de coordinación.
- Fortalecer los controles de continuidad operativa.
- Mejorar la preparación del personal participante.
- Reducir los tiempos de recuperación ante incidentes reales.

12.7 Conclusiones

La realización periódica de pruebas y simulacros constituye un elemento esencial para validar la efectividad del Plan de Continuidad Operativa y asegurar que la organización pueda responder de manera coordinada y eficiente ante situaciones de crisis.

El análisis sistemático de los resultados obtenidos permite fortalecer la resiliencia organizacional y mantener el plan alineado con los riesgos y necesidades operativas del centro comercial.

13. Conclusiones Generales

El desarrollo del presente **Plan de Continuidad Operativa y Recuperación ante Incidentes** permitió establecer una estructura integral de respuesta, coordinación y recuperación para un entorno de retail comercial, utilizando como caso de estudio a Montevideo Shopping.

El análisis efectuado evidencia que los principales riesgos para la continuidad del negocio se encuentran asociados a eventos **tecnológicos, operacionales y físicos**, destacándose especialmente los incidentes de **ransomware**, los **cortes eléctricos prolongados** y las afectaciones sobre **infraestructura crítica**.

La identificación de servicios esenciales, la definición de objetivos de recuperación, el establecimiento de procedimientos de respuesta inicial, la asignación de responsabilidades y la incorporación de mecanismos de comunicación y escalamiento proporcionan una base sólida para fortalecer la **resiliencia organizacional** y reducir el impacto potencial de futuras interrupciones.

Asimismo, la inclusión de **pruebas y simulacros periódicos** constituye un elemento clave para asegurar que el plan permanezca actualizado, validar la efectividad de los procedimientos definidos y mantener una adecuada capacidad de respuesta por parte de las áreas involucradas.

En términos generales, el presente documento demuestra cómo un enfoque alineado con buenas prácticas de **continuidad operativa, gestión de riesgos y resiliencia empresarial** puede contribuir a

mejorar la preparación de una organización frente a escenarios disruptivos que afecten sus operaciones críticas.

Finalmente, se concluye que la implementación progresiva de las medidas propuestas permitiría incrementar el nivel de preparación ante incidentes, mejorar los tiempos de recuperación y fortalecer la capacidad de la organización para mantener la continuidad de sus servicios esenciales en situaciones de contingencia.

14. Recomendaciones Finales

Como resultado del presente trabajo, se recomienda considerar las siguientes líneas de acción para fortalecer la continuidad operativa, la gestión de riesgos y la resiliencia del negocio:

✓ Formalizar un programa de continuidad del negocio alta Alineado con los principios establecidos por la norma ISO 22301.	Prioridad
✓ Implementar ejercicios periódicos de simulación alta Para validar la capacidad de respuesta ante incidentes críticos.	Prioridad
✓ Verificar regularmente la efectividad de los respaldos alta Mediante pruebas de restauración controladas.	Prioridad
✓ Fortalecer los controles de protección alta Frente a amenazas de ransomware y phishing.	Prioridad
✓ Revisar los acuerdos de servicio con proveedores críticos media Incorporando requisitos de continuidad y tiempos de respuesta.	Prioridad
✓ Actualizar anualmente el inventario de activos media Y los servicios esenciales para la operación.	Prioridad
✓ Definir procedimientos detallados de recuperación tecnológica media Para los sistemas considerados críticos.	Prioridad

✓ Desarrollar un comité de continuidad y gestión de crisis media Con participación de las principales áreas operativas y tecnológicas.	Prioridad
---	------------------

14.1 Análisis de Inversión vs. Reducción de Riesgo

Cada recomendación tiene un costo de implementación distinto y una reducción de riesgo distinta. Se propone la siguiente matriz de priorización (Impacto vs. Esfuerzo) para apoyar la toma de decisión de la Gerencia:

Recomendación	Costo relativo	Reducción de riesgo	Prioridad resultante
Pruebas de restauración de backups	Bajo	Alta	Hacer primero
Copia de backup inmutable/air-gapped	Bajo-Medio	Alta (mitiga ransomware)	Hacer primero
MFA en accesos remotos/administrativos	Bajo	Alta	Hacer primero
Simulacros periódicos	Bajo-Medio	Media-Alta	Corto plazo
Dual-WAN con failover	Medio	Media	Corto plazo
Revisión de SLA con proveedores	Bajo (costo de gestión)	Media	Corto plazo

Redundancia N+1 de generación eléctrica	Alto	Media (ya existe respaldo simple)	Evaluar según historial de fallas
Comité formal de continuidad + certificación ISO 22301	Medio (tiempo de gestión)	Alta (estructural)	Mediano plazo

Principio de priorización aplicado: se priorizan las acciones de bajo costo y alto impacto (pruebas de backup, MFA, segmentación básica) sobre las de alto costo y beneficio incremental (redundancia N+1), salvo que el historial de incidentes de la organización justifique lo contrario.

Priorización sugerida

Horizonte	Acciones recomendadas
0–3 meses Inmediato	• Verificación de respaldos. • Fortalecimiento de controles contra ransomware y phishing. • Actualización del inventario de activos críticos.
3–6 meses Corto plazo	• Implementación de simulacros. • Revisión de acuerdos con proveedores. • Definición de procedimientos de recuperación tecnológica.
6–12 meses Mediano plazo	• Formalización del programa de continuidad. • Creación del comité de continuidad y gestión de crisis. • Alineación progresiva con ISO 22301.

Conclusión

La aplicación progresiva de estas recomendaciones contribuirá a mejorar la capacidad de **prevención, detección, respuesta y recuperación** ante eventos que puedan afectar la operación del centro comercial.

En conjunto, las acciones propuestas permitirían fortalecer la resiliencia organizacional, reducir el tiempo de interrupción de los servicios críticos y mejorar el nivel de preparación frente a incidentes tecnológicos, operacionales y físicos que impacten la continuidad del negocio.